MSM ACADEMY

SECTION 11

Lead Auditor simulation



11.1 Briefing, Stage 1 and the Stage 2 plan
11.2 Opening, leadership, context and risk
11.3 People, access and suppliers
11.4 Operations, change and grading
11.5 Closing, report and what follows

Your role and your team

An independent certification audit

- You: Lead Auditor for the certification body; no involvement in Quenvale’s implementation
- Elif Aydın: auditor; Ravi Menon: technical expert in cloud security, working under your direction
- Criteria: ISO/IEC 27001:2022 and Quenvale’s own ISMS documentation

MSM ACADEMY

SECTION 11 · LESSON 11.1

Briefing, Stage 1 and the Stage 2 plan

11.1

Month 15

Stage 1: documented information reviewed

Document	What it shows
Scope statement	Three sites, cloud production and remote working; acquired start-up excluded; its API interface in scope
Risk register, treatment plan, SoA	Seven risks; 92 controls necessary, 8.30 excluded
Internal audit and management review	Audit at Month 7; review at Month 8
Handover list (Month 8)	Four items owned and dated, Months 9 to 12

LESSON 11.1 · CONVERSATION

“The boundary rests on one interface”



Elif Aydın Auditor, certification body

“The exclusion depends on that interface. The register rates it Low because the data is anonymised. Stage 2 should test that, not take it on trust.”

YOU

Your move: Decide what Stage 1 concludes, and what goes into the Stage 2 plan.

Your move: Stage 1 conclusions

You have:

- Documented information in place
- Internal audit and management review performed
- Four handover items due between Months 9 and 12
- A scope boundary that relies on an anonymised interface

Is Quenvale ready for Stage 2? Which areas of concern will you record?



Pause the video

Then compare with the model answer.

Model answer: Stage 1 conclusions

Readiness	Ready to proceed to Stage 2 at Month 17
Area of concern 1	Status of the four Month-8 handover items
Area of concern 2	The scope boundary and the controls on the anonymised interface
Not yet findings	At Stage 1, the evidence supports areas of concern for Stage 2 investigation



Stage 1 establishes readiness and focuses Stage 2.

Your move: the Stage 2 plan

Build the plan:

- Five trails: leadership and context; risk; people and access; suppliers; operations and change
- Three team members, two days on site
- Sampling by risk: where is the most significant risk?

Assign the trails and decide where to sample most deeply.



Pause the video

Then compare with the model answer.

Model answer: the Stage 2 plan

Trail	Interviews	Team
T1 Leadership, context, scope	Adaeze Okonkwo, Rafael Moreira	Lead Auditor
T2 Risk assessment and treatment	Rafael Moreira, Ivan Petrović	Lead Auditor
T3 People and access	Claire Dubois, Ivan Petrović	Elif Aydın
T4 Suppliers	Rafael Moreira, procurement records	Elif Aydın
T5 Operations and change	Sunita Rao	Lead Auditor with Ravi Menon

MSM ACADEMY

SECTION 11 · LESSON 11.2

Opening, leadership, context and risk

11.2

Month 17

LESSON 11.2 · STAGE 2

Opening meeting

What you confirm

- Scope, audit plan and trails; who will be interviewed and when
- Sampling: findings are based on samples of the available evidence
- Grading, confidentiality, and how to raise concerns, complaints or appeals

LESSON 11.2 · CONVERSATION

“The heatwave tested us”



Adaeze Okonkwo CEO

“Our objectives are on the board agenda now. And the heatwave two months ago tested us: the comms room alarm went off, but the team handled it.”

YOU

Your move: Follow her statement into the evidence before you conclude anything.

Climate and the comms room: records

Record	What it shows
Context record (Month 1)	Climate change determined relevant; heat at HQ named
Alarm log (Month 15)	Alarm at 31 °C; portable cooling deployed within 30 minutes; normal by afternoon; no outage
Incident register (Month 15)	Event logged; cooling upgrade added as action
Risk register Rev 01	R-02 updated at Month 15; cooling upgrade planned Months 16–19

Your move: the heatwave

Ask yourself:

- What did Quenvale’s own determination and procedure require?
- What happened, and is it recorded?
- Did the risk process respond?

Is there a finding here?



Pause the video

Then compare with the model answer.

Model answer: the heatwave

Criteria	Climate determination; portable-cooling procedure; risk process
Evidence	Alarm, response and recovery recorded; risk register updated; action planned
Conclusion	Conforming: the determination works in practice
Record	Note as positive evidence; no finding



An event is not a nonconformity; a requirement not met is.

LESSON 11.2 · CONVERSATION

“We had to keep the server running”



Rafael Moreira ISMS Manager

“Risk owners review their risks, and acceptances follow the criteria.”



Ivan Petrović IT Operations Manager

“The legacy server migration slipped at Month 12. I extended the interim controls and signed the acceptance. We had to keep the business running.”

YOU

Your move: Check the acceptance against Quenvale’s own criteria.

Risk register Rev 01: R-01 and the criteria

Item	Record
R-01 residual	8, High; risk owner: COO
Accepted by	Ivan Petrović, Month 12; authority level recorded: Risk owner
Authority check (tool)	Authority insufficient
Criteria (risk procedure)	High: temporary retention only with top-management approval and a dated plan

Your move: the R-01 acceptance

Criteria: Quenvale’s risk procedure and 6.1.3 (risk owners approve treatment and accept residual risk)

Evidence: acceptance of a High residual risk by the IT Operations Manager; required authority top management; risk owner the COO

Is this a nonconformity? Write the statement: requirement, evidence, why it is not met.



Pause the video

Then compare with the model answer.

Model answer: R-01 acceptance

Requirement	6.1.3 and the risk procedure: residual risk accepted by the risk owner at the authority the criteria require
Evidence	R-01 (High, 8) accepted at Month 12 by the IT Operations Manager at risk-owner level; criteria require top management
Statement	Nonconformity: residual risk acceptance not made at the required authority
Grade	Decided at the team grading meeting



Write what the evidence shows, not who to blame.

MSM ACADEMY

SECTION 11 · LESSON 11.3

People, access and suppliers

11.3

Month 17

LESSON 11.3 · CONVERSATION

“The NCR was closed at Month 10”



Claire Dubois HR Director

“Every employee completed awareness. After the internal audit we enrolled the contractors and fixed the onboarding checklist. The NCR was closed at Month 10.”

YOU

Your move: Test whether the corrective action worked, not only whether it was closed.

Awareness and contractor records

Record	What it shows
NCR close-out (Month 10)	Current contractors enrolled; checklist updated; effectiveness recorded “Yes”
Onboarding checklist (Month 10)	Awareness required before access
Agency onboarding list	CTR-026 to CTR-030 started Months 11 to 16; onboarded by the agency
Training register (Month 17)	Contractors in post at Month 10 completed; no later contractors listed

LESSON 11.3 · YOUR MOVE

Your move: contractor awareness

Criteria: 10.2 (corrective action taken and its effectiveness reviewed); 7.3

Evidence: corrective action closed Month 10 as effective; five contractors onboarded afterwards, not in the training register

What do you conclude, and against which requirement?



Pause the video

Then compare with the model answer.

Model answer: contractor awareness

Requirement	10.2: corrective action effective, and its effectiveness reviewed
Evidence	Five contractors onboarded Months 11–16 through the agency, not enrolled; action closed as effective at Month 10
Statement	Nonconformity: the corrective action did not prevent recurrence and its effectiveness was not established
Grade	Decided at the team grading meeting



Closure is not effectiveness.

LESSON 11.3 · CONVERSATION

“That was the team lead’s job”



Ivan Petrović IT Operations Manager

“Quarterly access reviews were run by the support centre’s operations team lead. They did a thorough one at Month 7.”

YOU

Your move: Follow the review schedule through to Month 17.

Access review records

Record	What it shows
Access review schedule and record	Month 7 completed; Months 10, 13, 16: no record
HR leaver record	Operations Team Lead left at Month 10; operational duties handed to the support centre manager
Monitoring results (Month 12)	O1: not reported — Month-10 access review not performed
Access policy	Quarterly reviews of critical systems; owner the Operations Team Lead

LESSON 11.3 · YOUR MOVE

Your move: access reviews

Criteria: the access policy (quarterly reviews) and Annex A 5.18 as implemented in Quenvale’s SoA

Evidence: three scheduled reviews without records since the reviewer left

What do you conclude?



Pause the video

Then compare with the model answer.

Model answer: access reviews

Requirement	Annex A 5.18 as implemented; the access policy: quarterly reviews
Evidence	Reviews due Months 10, 13 and 16 not performed after the reviewer left; task not reassigned
Statement	Nonconformity: access rights not reviewed as the organization defined
Grade	Decided at the team grading meeting

Follow a control to the person who runs it, and what happens when they leave.

Personal phones

Observation and record	What it shows
Observed on site	Staff reading company email on personal phones
BYOD policy	Email and chat allowed only through managed app protection; no customer-data downloads
App-protection report (Month 17)	All personal-phone access through managed apps; unmanaged access and downloads blocked

Your move: personal phones

Criteria: the BYOD policy and the related controls as implemented

Evidence: staff reading company email on personal phones; the app-protection report

Is there a finding?



Pause the video

Then compare with the model answer.

Model answer: personal phones

Criteria	The BYOD policy and 6.7, 8.1 as implemented
Evidence	Use observed matches the policy; the report shows the controls working
Conclusion	Conforming: allowed by policy, with managed app protection
Record	Note as positive evidence; no finding



Something that looks risky can still conform.

LESSON 11.3 · CONVERSATION

“They never answer questionnaires quickly”



Rafael Moreira ISMS Manager

“The code repository supplier is the hardest. They’re big and slow with questionnaires. It’s booked for Month 18.”

YOU

Your move: Check the supplier reassessments against the schedule.

Supplier reassessment status

Tier-1 supplier	Due	Status at Month 17
Public cloud provider	Month 9	Completed Month 9
Identity provider	Month 10	Completed Month 10
Code repository and pipeline	Month 10	Not performed; rescheduled to Month 18
Managed detection and response	Month 11	Completed Month 11
Banking file gateway	Month 12	Completed Month 12

LESSON 11.3 · YOUR MOVE

Your move: supplier reassessment

Criteria: Quenvale’s supplier procedure (tier 1 reassessed annually) and Annex A 5.22 as implemented

Evidence: one tier-1 supplier’s reassessment seven months overdue at Month 17

What do you conclude?



Pause the video

Then compare with the model answer.

Model answer: supplier reassessment

Requirement	Annex A 5.22 as implemented; annual tier-1 reassessment
Evidence	Code repository supplier due Month 10, not reassessed at Month 17; four others on schedule
Statement	Nonconformity: supplier service monitoring not performed as defined for one tier-1 supplier
Grade	Decided at the team grading meeting



A reason for a delay is not evidence of control.

MSM ACADEMY

SECTION 11 · LESSON 11.4

Operations, change and grading

11.4

Month 17

Incident records

Record	What it shows
Incident register	INC-27 phishing, Month 10; closed Month 11
Incident report INC-27	Detected within hours by the managed provider; session revoked; exposure ruled out
Notification decision	Recorded within 24 hours: no notification required
Lessons learned	Phishing refresher for the support centre; additional sign-in alerting

LESSON 11.4 · YOUR MOVE

Your move: the phishing incident

Criteria: Quenvale’s incident procedure: detection, response, a notification decision within 24 hours, lessons learned

Evidence: the incident register and report INC-27

Is there a finding?

Pause the video

Then compare with the model answer.

Model answer: the phishing incident

Criteria	Incident procedure: detection, response, notification decision, lessons
Evidence	Each step recorded within the procedure’s timescales
Conclusion	Conforming: the incident process worked
Record	Note as positive evidence; no finding



Incidents happen; the audit question is whether the process worked.

Restore test report (Month 11)

Item	Record
Requirement (backup policy)	Full restore test twice a year against RTO 8 h and RPO 24 h
Restore	Production database restored in 6 hours, to the previous day’s backup point
Checks performed	Table and record counts compared with the source
Application functional checks	Not performed
Result recorded	Passed

LESSON 11.4 · YOUR MOVE

Your move: the restore test

Compare:

- What the policy requires: a full restore test against the recovery objectives
- What was done: a database restore within the objectives; record counts compared; no application checks

Nonconformity, opportunity for improvement, or conforming? Why?



Pause the video

Then compare with the model answer.

Model answer: the restore test

Requirement met?	Yes: full restore within RTO and RPO, as the policy requires
Weakness	Without application checks, the test gives limited assurance the platform works after restore
Classification	Opportunity for improvement
Not	A nonconformity: no requirement prescribes application checks

Grade against the criteria, not against what you would have done.

LESSON 11.4 · CONVERSATION

“Every change goes through code review”



Sunita Rao Head of Engineering

“The analytics feed is anonymised and aggregated. Every change goes through code review, and the first change had a full security review.”

YOU

Your move: Test the interface control from the change records.

Interface changes and the procedure

Record	What it shows
Change procedure (L3-PRC-004)	Every change to the interface needs a documented security review before release
CHG-041, Month 5	Interface security review recorded
CHG-079, Month 12: schema extension	Code review only
CHG-091, Month 14: add postcode and job grade	Code review only
Change request form	No field prompting the interface security review

LESSON 11.4 · CONVERSATION

“Let me look at the data itself”



Ravi Menon Technical expert

“The record-level tables carry a pseudonymous key, salary band and department, and since Month 14 postcode and job grade. The system’s group-size report shows 61 records unique within their customer.”

YOU

Your move: Weigh what the data could reveal, and what actually happened.

The interface: remaining evidence

Record	What it shows
Feed access log, Months 14–17	Start-up analysts queried record-level tables; no evidence of re-identification
Risk register Rev 01	R-03 still Low because “anonymised”; last reviewed Month 8
Quenvale’s own records	No record that Quenvale identified the issue
Scope statement	Exclusion justified by the interface receiving anonymised, aggregated data

Your move: the interface

Answer from the evidence:

- One change, or more?
- How many people could be identified, and with what data?
- Did anyone re-identify anyone? Did Quenvale detect it?
- One person’s lapse, or a weakness in the process?
- What do the risk assessment and the scope justification now rest on?

Write the finding and its requirement. Grading follows at the team meeting.



Pause the video

Then compare with the model answer.

Model answer: the interface

Evidence answers	Two changes skipped the review; about 60 people re-identifiable via postcode and job grade, linkable to salary bands; no re-identification found; not detected by Quenvale
Process	The change process has no trigger for the review: a systemic weakness, not one lapse
Statement	Nonconformity: interface changes released without the required security review (8.32; 5.34 personal data)
Scope	The exclusion depends on anonymisation that the evidence no longer supports; addressed in corrective action



Classify only after the whole evidence set.

LESSON 11.4 · CONVERSATION

“As serious as it looks?”



Elif Aydın Auditor

“Before we grade: nobody was re-identified, and they only added two fields. Is the interface really as serious as it looks?”

YOU

Your move: Grade every finding, using the certification definitions.

Your move: the grading meeting

Definitions (ISO/IEC 17021-1):

- Major: affects the capability of the management system to achieve its intended results, e.g. significant doubt about effective control, or a systemic failure
- Minor: does not affect that capability

Findings: R-01 acceptance · contractor awareness · access reviews · supplier reassessment · the interface

Grade each finding, and answer Elif.



Pause the video

Then compare with the model answer.

Model answer: grading

Finding	Grade	Why
R-01 acceptance (6.1.3)	Minor	One acceptance at the wrong authority; the process otherwise works
Contractor awareness (10.2)	Minor	Ineffective corrective action, limited to later contractors
Access reviews (5.18)	Minor	One control’s reviews lapsed after an owner left
Supplier reassessment (5.22)	Minor	One overdue supplier; four on schedule
Interface (8.32, 5.34)	Major	Repeated, systemic failure; significant doubt about control of personal data

MSM ACADEMY

SECTION 11 · LESSON 11.5

Closing, report and what follows

11.5

Month 17

LESSON 11.5 · CONVERSATION

“Recommend us anyway”



Adaeze Okonkwo CEO

“One major? Our customers need the certificate this month. Can’t you recommend certification now, and we fix the feed afterwards?”

YOU

Your move: Decide what you can recommend, and what Quenvale must do next.

LESSON 11.5 · YOUR MOVE

Your move: the recommendation

Rules (ISO/IEC 17021-1, Section 9):

- Majors: correction and corrective action reviewed, accepted and verified before a decision
- Minors: correction and corrective-action plans reviewed and accepted
- The decision is made by the certification body, not the audit team
- Auditors explain findings; they do not prescribe solutions

What do you tell Adaeze, and what do you recommend?



Pause the video

Then compare with the model answer.

Model answer: the recommendation

To Adaeze	Certification cannot be recommended until the major is corrected and its corrective action verified
Next steps	Quenvale submits cause analysis, correction and corrective action for all five, within the agreed timeframe
Verification	The major verified, on site if needed; minor plans reviewed and accepted
Boundary	You explain the findings and requirements; Quenvale designs the fix



Be clear, be fair, and stay independent.

LESSON 11.5 · REPORT

The audit report

Section	Content
Scope and criteria	Scope as certified; ISO/IEC 27001:2022 and Quenvale’s ISMS
Conclusion	Recommendation withheld pending verification of the major
Findings	1 major, 4 minor nonconformities; 1 opportunity for improvement
Positive evidence	Climate response, incident handling, managed personal phones
Limits	Findings based on samples; no evidence of re-identification found

SECTION 11 · RECAP

What you did as Lead Auditor

- Planned by risk and followed evidence, not assumptions
- Wrote findings against requirements, then graded with the team
- Recognized conformity where it existed
- Stayed independent at the closing meeting

Check your understanding

Quenvale’s restore test met its recovery objectives but skipped application checks, which no requirement prescribes. What should the auditor record?

A. A minor nonconformity against 8.13

B. An opportunity for improvement in restore testing

C. A major nonconformity, because recovery is unproven

D. Nothing, because the test passed

Check your understanding

Quenvale’s restore test met its recovery objectives but skipped application checks, which no requirement prescribes. What should the auditor record?

A. A minor nonconformity against 8.13

B. An opportunity for improvement in restore testing

C. A major nonconformity, because recovery is unproven

D. Nothing, because the test passed

Answer: B

Where the requirement is met but effectiveness could be improved, the auditor records an opportunity for improvement. A nonconformity needs an unmet requirement.

MSM ACADEMY

SECTION 11 COMPLETE

Next: Section 12

Course completion and certificate

